

POLÍTICA DE SEGURANÇA OPERACIONAL

Padrões de cópias de segurança, recuperação e gestão de vulnerabilidades

Organização	Entidade
Identificador	PSO-004
Versão	1.0 — Proposta para revisão e aprovação
Classificação	Uso interno
Proprietário	Função responsável definida pela Direcção
Aprovação	Direcção / órgão competente
Data de emissão	09 de Outubro de 2026
Revisão	Anual ou após alteração relevante

Nota de controlo: Documento de referência para validação interna. A aprovação deve ser precedida da confirmação das responsabilidades, dos requisitos legais e regulamentares aplicáveis, dos canais operacionais e dos controlos efectivamente implementados.

Histórico e controlo do documento

Versão	Data	Descrição	Responsável
1.0	09/10/2026	Emissão inicial para revisão	Função responsável

1. Objectivo e âmbito

Definir os requisitos mínimos para operar e manter sistemas de forma segura, incluindo cópias de segurança, recuperação, actualizações, configuração segura e gestão de vulnerabilidades. Aplica-se a infra-estruturas, aplicações, bases de dados, redes, endpoints, serviços cloud e sistemas de terceiros que suportem processos relevantes.

2. Operação segura e gestão de alterações

- As alterações devem ser solicitadas, avaliadas quanto ao risco, aprovadas, testadas e registadas antes da implementação, excepto em emergência devidamente documentada.
- Os ambientes de desenvolvimento, teste e produção devem ser separados quando viável, com acesso controlado.
- As configurações de referência devem ser documentadas e revistas; serviços, portas, contas e funcionalidades desnecessárias devem ser desactivados.
- Os activos e sistemas críticos devem ter proprietário, classificação, dependências e criticidade documentadas.
- As actividades operacionais devem ser executadas por pessoas autorizadas e com segregação adequada.

3. Gestão de vulnerabilidades

3.1. Identificação

As vulnerabilidades devem ser identificadas por fontes de segurança fiáveis, inventário tecnológico, avisos de fabricantes, ferramentas de análise, testes autorizados e informação de ameaças. A cobertura e a frequência devem ser proporcionais à criticidade e exposição dos activos.

3.2. Avaliação e prioridade

A prioridade deve considerar severidade técnica, exposição à internet, existência de exploração activa, criticidade do activo, sensibilidade dos dados e impacto operacional. Uma pontuação automática não substitui a avaliação contextual.

3.3. Correção e aceitação de risco

Cada vulnerabilidade relevante deve ter responsável, prazo, acção correctiva e evidência de validação. Quando a correcção imediata não for possível, devem ser aplicadas medidas compensatórias e registada a aceitação temporária do risco pela autoridade competente.

3.4. Verificação

Após a correcção, deve confirmar-se que a vulnerabilidade foi resolvida e que a alteração não introduziu falhas adicionais. As vulnerabilidades exploradas ou de impacto elevado devem ser escaladas para gestão e avaliadas quanto a possível incidente.

4. Cópias de segurança

- A frequência e a retenção das cópias devem ser definidas segundo criticidade, volume de alterações, requisitos legais e objectivos de recuperação.
- As cópias devem ser protegidas por controlo de acesso, encriptação quando adequada e separação dos sistemas de produção.
- Devem existir cópias isoladas ou imutáveis para os sistemas críticos sempre que viável, reduzindo o risco de destruição por ransomware ou comprometimento administrativo.
- As tarefas devem ser monitorizadas; falhas devem gerar alerta, investigação e repetição controlada.
- A restauração deve ser testada periodicamente, incluindo integridade, disponibilidade e capacidade de cumprir os objectivos de recuperação.
- O acesso a repositórios de backup deve ser limitado e separado, quando possível, dos privilégios administrativos de produção.

5. Continuidade e recuperação

Os responsáveis pelos serviços devem definir objectivos de tempo de recuperação (RTO) e ponto de recuperação (RPO), aprovados pelo negócio e compatíveis com a capacidade real. Os planos devem identificar dependências, responsáveis, procedimentos alternativos, critérios de activação e comunicação.

- Os testes devem incluir cenários relevantes, como indisponibilidade, corrupção de dados, falha de fornecedor e ataque de ransomware.
- Resultados, falhas e acções correctivas devem ser registados; a existência de backups não prova, por si só, que a recuperação funciona.
- Os procedimentos de recuperação devem ser actualizados após alterações relevantes de sistemas e arquitectura.

6. Registos, monitorização e protecção contra malware

Os sistemas críticos devem gerar registos suficientes para investigação e monitorização, com relógios sincronizados, acesso restrito e protecção contra alteração. Devem ser aplicados controlos contra código malicioso, gestão de actualizações, protecção de endpoints e alertas para actividades anómalas, de acordo com o risco.

7. Fornecedores e serviços externos

A segurança operacional de serviços externalizados deve ser avaliada antes da contratação e acompanhada durante a relação. Devem ser definidos requisitos de disponibilidade, cópias de segurança, notificação de vulnerabilidades, gestão de alterações, resposta a incidentes, recuperação e devolução de dados.

Responsabilidades principais

Papel	Responsabilidades
Direcção / proprietários de serviços	Aprovar prioridades, RTO/RPO e aceitação de risco residual dentro da autoridade atribuída.
TI / Operações	Executar alterações, actualizações, backups, monitorização e recuperação, mantendo evidências.
Segurança da Informação	Definir critérios de risco, acompanhar vulnerabilidades e verificar a eficácia dos controlos.
Responsáveis de aplicações e dados	Confirmar criticidade, requisitos de recuperação e testes funcionais após restauração.
Fornecedores	Cumprir os requisitos contratuais e comunicar falhas ou vulnerabilidades relevantes.

Monitorização e evidências

A função responsável deve definir a periodicidade, fonte, responsável e destinatário de reporte dos indicadores abaixo, mantendo evidências proporcionais ao risco e aos requisitos aplicáveis.

- Percentagem de backups concluídos com sucesso.
- Percentagem de testes de restauro bem-sucedidos.
- Número de vulnerabilidades críticas/elevadas fora do prazo.
- Tempo médio de correcção por severidade.
- Percentagem de sistemas críticos com RTO/RPO aprovados e testados.
- Número de alterações urgentes sem revisão posterior concluída.

Excepções, incumprimento e revisão

Qualquer excepção deve ser solicitada por escrito, justificada, avaliada quanto ao risco, aprovada pela autoridade competente, limitada no tempo e acompanhada de medidas compensatórias. Não pode contrariar obrigações legais ou regulamentares. O incumprimento pode resultar em medidas correctivas, restrição de acessos ou consequências disciplinares e contratuais, conduzidas pelas áreas competentes. O documento deve ser revisto pelo menos anualmente e após alterações relevantes, incidentes significativos ou mudanças legais.

Aprovação formal

Etapa	Responsável / nome	Assinatura e data
Elaboração	A preencher	A preencher
Revisão técnica / jurídica	A preencher	A preencher
Aprovação — Direcção competente	A preencher	A preencher

Entrada em vigor: após aprovação formal e divulgação aos destinatários abrangidos.